

Module 1

9 courses made up of modules

Aimed at entry level candidates

CIA triad

↳ Confidentiality, integrity, availability

Other internal threats are accidental.

Phishing tactic - social engineering

Phishing indicator - technical red flags

Content indicators - red flags in body of email

3 responsibilities of cyber analyst:

- Protect computers + data
- install prevention software
- conduct audits

engineers vs analysts - engineers focus more on products.

Analysts may write playbooks - lists for detection investigation.

common terms

Compliance - adhering to regulations

Frameworks - guidelines for security plans

Controls - reduce certain security risks

also view the NIST glossary.

Core Skills

Transferable vs technical skills

↓
communication
collaboration
Analysis
Problem Solving

↓
Programming
SIEM tools
Forensics

PII - personally identifiable information

SPII - sensitive " , stricter regulations

Module 2

Past cybersecurity attacks

Virus - malicious code that attaches to Programs or documents and spreads

- Brain virus - 1986, designed to track illegal copies - infected disks put into infected machines.
- Morris worm - 1988, Program to check size of web, replicated across computers and caused outages.

Using the internet allowed threat actors to spread malware without physical media

- Love letter - designed to harvest credentials, emailed people via address books

Social engineering exploits user behavior to gain information

Phishing is specifically using digital communications.

Common attacks

Phishing

- ↳ Business email compromise - email from known source to further their access to information.
- ↳ Spear phishing - targeted phishing attack
- ↳ Whaling - spear phishing against business execs
- ↳ Vishing - phishing over VOIP or similar
- ↳ Smishing - phishing over sms

Malware

- ↳ Viruses - malicious code installed by user and hides in files or programs
- ↳ Worms - malware with duplication capabilities and can self-replicate
- ↳ Ransomware - malware that encrypts files and demands payment to decrypt them.
- ↳ Spyware - malware that gathers and sells PII from devices.

Social engineering

- ↳ Social media phishing - spear phishing using OSINT
- ↳ Watering hole - attacks a frequently visited website.
- ↳ USB baiting - leaving malicious USB's for people to plug in
- ↳ Physical - impersonation

Social engineering pillars

- Authority
- Intimidation
- Consensus
- Scarcity
- Familiarity
- Trust
- Urgency

The 8 CISSP domains

1. Security & risk management

define security goals, objectives, risk mitigation, compliance

2. Asset security

Secure digital and physical assets the storage, retention and destruction of assets

3. Security architecture and engineering

Optimise data security by ensuring effective tools, systems and processes.

4. Communication and network security

Secure networks and communications, including physical hardware.

5. Identity and access management

Keeps data secure by ensuring users follow policies for physical assets and logical assets

6. Security assessment and testing

Security control testing, audits and data analysis

7. Security operations

Investigations and preventable operations.

8. Software development security

Following security practices during software development.

Threat actors

APTs - advanced persistent threats have significant resources or expertise.

Insider threats

Hacktivists

Module 3

Security Frameworks and Controls

- Start by identifying critical assets
- implement plans
- review

Frameworks provide guidelines to assist in making plans

Components of frameworks

- ↳ identify and document goals
- ↳ set guidelines to achieve goals
- ↳ implement processes
- ↳ Monitoring and communicating

Controls are safeguards to reduce specific risks,

CIA triad

- ↳ confidentiality - only certain users can access assets
- ↳ integrity - data is tamper free
- ↳ availability - data is available when needed

NIST CSF is a framework to manage risk

PCI DSS is an international standard to ensure that Payment Processing is done in a secure way

ISO - international standards for technology

ethics

guidelines for making appropriate decisions for security professionals

Principles

- ↳ confidentiality → PII needs to be protected.
- ↳ Privacy → safeguarding information.
- ↳ Laws

Always adhere to organisational policies.

Counter attacks are almost always illegal, the international court of justice decries when it is acceptable but this is hard to measure so basically never allowed.

Module 4

Common tools

Log - record of events stored on devices.

SIEM tools - collect and analyse log data in real time, provide alerts on specific types of events

↳

Splunk

Chronicle - Google tool

ELK stack

Playbook - manual providing details as to how to handle certain incidents.

Network protocol analyser - captures network data.

